Corrigé — Labo Détection avec Suricata

Nov 4, 2026 · Francois Paquin, CISSP

Ce corrigé donne les résultats obtenus en exécutant le labo sur un environnement Ubuntu 26.04, sauf les éléments indiqués comme non testés.

Partie 1 — Installer et vérifier

Résultat attendu : 48 alertes de la règle 1000000, soit une par requête `GET` décodée.

Q1.

Option	Rôle
`-c`	Fichier de configuration principal
`--include`	Fichier ajouté qui modifie certaines clés
`-S`	Utilise seulement ce fichier de règles, sans ceux de la configuration
`-r`	Lit une capture plutôt qu'une interface
`-k none`	Ne rejette pas les paquets selon leur somme de contrôle
`-l`	Dossier des journaux

Q2. `HOME_NET` décrit le réseau que le capteur protège dans le trafic observé. Ici, c'est `10.9.10.0/24`. L'adresse de la VM d'analyse n'apparaît jamais dans la capture.

Q3. Une capture peut contenir des sommes de contrôle invalides, souvent à cause du déchargement vers la carte réseau. Suricata pourrait alors ignorer ces paquets et manquer des sessions.

Partie 2 — Lire ce que Suricata produit

À retenir : avant même d'écrire une règle, `eve.json` donne une grande partie de ce que l'exercice a demandé avec trois outils.

Q1. On trouve notamment `alert`, `dns`, `http`, `tls`, `smb`, `dcerpc`, `fileinfo`, `krb5`, `ldap`, `dhcp`, `flow`, `anomaly`, `mdns` et `stats`. Suricata est aussi un moteur de surveillance de la sécurité réseau (NSM) : il journalise les protocoles, les flux et les fichiers même sans alerte.

Q2. Non, NetFlow ne le montre pas. Ici, 11 événements `krb5` portent `hobart.gunnarsson`, et 7 valent `<empty>`.

```
jq -r 'select(.event_type=="krb5") | .krb5.cname' sortie/eve.json | sort | uniq -c
```

Q3. 34 connexions : 33 vers `94.158.245.52` et une vers `167.172.37.9`.

```
jq -r 'select(.event_type=="tls" and .tls.sni==null) | .dest_ip' sortie/eve.json |
sort | uniq -c
```

Q4. Le `flow_id` relie une alerte aux événements HTTP, fichier et flux de la même connexion. L'analyste passe ainsi de l'alerte au contexte sans chercher dans les paquets.

```
F=$(jq -r 'select(.event_type=="http" and .http.hostname=="simpsonsavingss.com") | .flow_id' sortie/eve.json)
jq -c --argjson f "$F" 'select(.flow_id==$f) | .event_type' sortie/eve.json
```

Q5. Accepter notamment : IP et MAC du poste, compte et domaine Kerberos, noms DNS, URL, User-Agent, nom de fichier proposé, SNI et champs du certificat. Le SHA256 n'apparaît qu'après le réglage de l'étape 3.5. Par défaut, l'événement `dhcp` observé ne donne pas le nom d'hôte.

Partie 3 — Règles à partir des IOC

Toutes ces règles déclenchent sur la capture. Accepter toute variante qui donne le même résultat et dont l'étudiant explique le nombre d'alertes.

Étape	sid	Alertes	Explication attendue
3.1	1000001	2	Requête DNS retransmise après 80 ms, même identifiant `0x9e41`
3.2	1000002	1	Une seule requête de téléchargement
3.3	1000003	35	33 sessions C2, plus une vers chacune des deux autres adresses
3.4	1000004	12	11 sessions C2 complètes, plus celle de `167.172.37.9`
3.5	1000005	0, puis 1	Le fichier est tronqué avant le réglage

3.1 Le domaine

```
alert dns $HOME_NET any -> any any (msg:"AP - Resolution du domaine de telechargement"; flow:to_server; dns.query; content:"simpsonsavingss.com"; nocase; endswith; classtype:trojan-activity; sid:1000001; rev:1;)
```

Vérification possible dans Wireshark : `dns.qry.name contains "simpsonsavingss"`.

3.2 L'URL

```
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"AP - Telechargement de BazarLoader"; flow:established,to_server; http.host; content:"simpsonsavingss.com"; endswith; http.uri; content:"/bmdff/"; startswith; classtype:trojan-activity; sid:1000002; rev:1;)
```

Le nom `date1` est court et change d'une campagne à l'autre. Seul, il créerait des faux positifs et serait facile à contourner.

3.3 Les adresses IP

```
alert ip $HOME_NET any -> [94.158.245.52,167.172.37.9,194.62.42.206] any (msg:"AP - Contact avec une IP malveillante"; classtype:trojan-activity; sid:1000003; rev:1;)
```

Une règle sans contenu à inspecter, basée seulement sur les adresses, n'est évaluée qu'une fois par flux et par sens. On obtient donc une alerte par session, pas une par paquet.

3.4 Le certificat

```
alert tls $EXTERNAL_NET any -> $HOME_NET any (msg:"AP - Certificat du C2";
flow:established,to_client; tls.cert_subject; content:"CN=londonareloeli.uk";
endswith; classtype:trojan-activity; sid:1000004; rev:1;)
```

22 des 33 sessions C2 portent `session_resumed: true`. La reprise de session abrège la poignée de main et saute l'envoi du certificat. Une règle basée sur le certificat voit donc une partie des sessions, mais assez pour repérer l'infrastructure.

3.5 L'empreinte du fichier

```
alert http any any -> any any (msg:"AP - Empreinte SHA256 de BazarLoader";
filesha256:mauvais.sha256; classtype:trojan-activity; sid:1000005; rev:1;)
```

État	Taille dans `fileinfo`	État du fichier	SHA256
Limite par défaut de 100 Kio	102 400 octets	`TRUNCATED`	Aucun
`response-body-limit: 0`	284 816 octets	`CLOSED`	`eed363fc…957cf8`

Le réglage retire la limite d'inspection du corps de la réponse HTTP. En production, inspecter davantage augmente la mémoire et le temps de traitement, et une valeur illimitée expose le capteur à de gros transferts. Il faut viser un compromis adapté à la taille des fichiers à inspecter.

Partie 4 — Détecter sans connaître l'IOC

Ces règles restent valables si le domaine, les IP et le fichier changent. Elles exigent toutefois un réglage selon le réseau.

4.1 Un exécutable reçu en HTTP

Avant l'exclusion, il y a 2 alertes : `date1` et le fichier `am_delta_patch_1.349.439.0_….exe` de `au.download.windowsupdate.com`, une mise à jour de Defender. Après l'exclusion, il reste 1 alerte, à 23:17:29.

```
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"Marque Windows Update";
flow:established,to_server; http.host; content:"windowsupdate.com"; endswith;
flowbits:set,labo.windowsupdate; flowbits:noalert; sid:1000006; rev:1;)

alert http $EXTERNAL_NET any -> $HOME_NET any (msg:"Executable Windows recu en HTTP
hors Windows Update"; flow:established,to_client;
flowbits:isnotset,labo.windowsupdate; file.data; content:"MZ"; depth:2; content:"This
program cannot be run in DOS mode"; distance:0; within:128; classtype:bad-unknown;
sid:1000007; rev:2;)
```

Risque de l'exclusion : l'en-tête `Host` est contrôlé par le client. Un maliciel pourrait y inscrire un nom qui se termine par `windowsupdate.com` pour échapper à la règle.

4.2 Du TLS sans SNI

Sans seuil, 34 alertes. Sur un vrai réseau, certains clients légitimes, outils internes et appareils se connectent aussi par adresse IP sans SNI.

```
alert tls $HOME_NET any -> $EXTERNAL_NET any (msg:"Repetition de TLS sans SNI vers
une meme IP"; flow:established,to_server; tls.sni; absent; threshold:type both, track
by_dst, count 5, seconds 3600; classtype:bad-unknown; sid:1000008; rev:2;)
```

Avec le seuil, 2 alertes pour `94.158.245.52` : 23:19:21 et 00:30:19. La première arrive environ 1 min 45 s après le premier contact C2 de 23:17:36.

4.3 L'énumération du domaine

La règle sur l'interface seule donne 57 alertes : 15 à 23:16 et 42 à 23:19. Celles de 23:16 viennent de l'ouverture de session normale.

```
jq -r 'select(.alert.signature_id==SID) | .timestamp[11:16]' sortie/eve.json | sort |
uniq -c
```

Remplacer `SID` par le numéro de la règle. La version affinée donne 2 alertes, à 23:19:27.

```
alert smb $HOME_NET any -> any any (msg:"Enumeration SAMR du groupe domain admins";
flow:established,to_server; dcerpc.iface:12345778-1234-abcd-ef00-0123456789ac;
dcerpc.stub_data; content:"d|00|o|00|m|00|a|00|i|00|n|00|
|00|a|00|d|00|m|00|i|00|n|00|s|00|"; nocase; classtype:bad-unknown; sid:1000009;
rev:1;)
```

4.4 La vérification de l'IP publique

```
alert tls $HOME_NET any -> $EXTERNAL_NET any (msg:"Poste qui verifie son IP
publique"; flow:established,to_server; tls.sni; content:"myexternalip.com"; endswith;
classtype:bad-unknown; sid:1000010; rev:1;)
```

Cette règle donne 1 alerte. Le service est légitime : son usage n'indique pas à lui seul une infection. Il devient parlant dans le contexte, ici avec le beaconing et l'énumération.

Partie 5 — Surveiller en direct avec EveBox

Le rejeu à `--multiplier=60` a duré 76,84 s, sans paquet perdu, et a conservé le rythme du beaconing.

5.3 Trier les alertes

Q1. La boîte Inbox regroupe les alertes semblables. La colonne **#** indique le nombre d'occurrences du groupe. Par exemple, 33 pour le contact avec `94.158.245.52`.

Q2. Archive retire l'alerte de la boîte une fois traitée. L'étoile **Escalate** la place dans **Escalated** pour un suivi.

Q3. Une seule vue donne l'alerte, le `flow_id`, les volumes du flux, la requête HTTP, le User-Agent, l'URL, le nom de fichier `date6` et le SHA256.

Q4. Exemple : archiver la règle de test et escalader l'empreinte SHA256 ou le contact C2. Accepter toute décision justifiée par le risque et le contexte.

5.4 Comparer le direct et le fichier

Q1. Les alertes portent l'heure du rejeu, car Suricata horodate les paquets à leur arrivée sur l'interface. En mode `-r`, il conserve celle de la capture. Pour la chronologie de l'incident, on se fie donc à `sortie/eve.json`.

Q2. Fichier : 105 alertes. Direct : 104 alertes. L'écart vient de la règle 1000008, avec 2 alertes contre 1. Son seuil de 3 600 s suit le temps de rejeu en direct : à 60 fois la vitesse, les 73 minutes tiennent dans une seule fenêtre.

Q3 et Q4. Résultat de référence sur 2 vCPU, avec les règles de l'essai :

Vitesse	Durée	Pertes	Alertes
`--multiplier=60`	76,84 s	0 %	244
`--mbps=10`	4,82 s	0 %	244
`--topspeed`	0,014 s	20,63 %	154

Ce tableau vient d'un jeu de règles d'essai plus large que le corrigé, mais il montre l'effet attendu : sans pertes, les alertes restent stables, alors qu'avec 20 % de pertes, les sessions C2 détectées passent de 33 à 9. Une alerte absente ne prouve donc pas l'absence d'attaque. Le capteur doit être dimensionné pour la pointe de trafic, et ses pertes doivent être surveillées.

Partie 6 — Synthèse

Le message à faire ressortir : les IOC donnent des alertes précises mais fragiles, alors que les comportements résistent mieux au changement et demandent plus de réglage.

Règle (sid)	Ce qu'elle détecte	Alertes	Facile à contourner ?	Risque de faux positifs	À garder en production ?
1000005	SHA256 du fichier	1	Très facile : recompiler	Très faible	Pendant la réponse à l'incident
1000003	Trois adresses IP	35	Facile : changer de serveur	Faible, mais une IP peut être réattribuée	Temporairement
1000001	Domaine	2	Facile : nouveau domaine	Faible	Temporairement
1000004	Certificat de l'attaquant	12	Moyen : générer un autre certificat	Très faible	Oui, avec une date de revue
1000007	Exécutable reçu en HTTP	1	Moyen : passer en HTTPS	Moyen	Oui, avec des exclusions revues

Règle (sid)	Ce qu'elle détecte	Alertes	Facile à contourner ?	Risque de faux positifs	À garder en production ?
1000008	TLS répété sans SNI	2	Moyen : envoyer un SNI	Moyen	Oui, après réglage
1000009	Requête SAMR sur `domain admins`	2	Difficile sans changer l'outil	Moyen : outils d'administration	Oui, si les sources d'administration sont exclues

Ces évaluations sont des repères de discussion. Accepter d'autres choix bien justifiés.

Q1. Déclenchent encore : 1000007, 1000008, 1000009 et 1000010, tant que l'attaquant garde les mêmes comportements. Ne déclenchent plus : 1000001, 1000002, 1000003 et 1000005. La règle 1000004 ne déclenche plus si le certificat change.

Q2. La plus tôt est 1000001, à 23:17:27, si le domaine est déjà connu. Sans IOC, c'est 1000007, à 23:17:29, pendant le téléchargement. Dans les deux cas, il restait environ 2 minutes avant l'énumération de 23:19:26.

Q3. Accepter notamment : ce qui s'est passé sur le poste, le processus lancé, le contenu chiffré du C2, le courriel initial, ainsi que la famille du maliciel sans source de renseignement externe.

Bonus

Datasets

La règle IP donne 37 alertes et la règle de domaine en donne 2.

```
alert tcp $HOME_NET any -> $EXTERNAL_NET any (msg:"Liste IOC - IP"; flags:S,12;
ip.dst; dataset:isset,ioc-ip,type ipv4,load ioc-ip.lst; classtype:trojan-activity;
sid:1000011; rev:1;)

alert dns $HOME_NET any -> any any (msg:"Liste IOC - domaine"; flow:to_server;
dns.query; dataset:isset,ioc-dom,type string,load ioc-dom.lst; classtype:trojan-
activity; sid:1000012; rev:1;)
```

Les datasets de type `string` se chargent en base64, ce qui permet n'importe quel octet dans une valeur. La règle IP compte chaque paquet SYN : deux sessions C2 ont un SYN retransmis (ports 58194 et 58240), d'où 37 plutôt que 35.

ET Open

Non testé. Faire le bonus une fois dans le Cyber Range avant de fixer une réponse attendue. Ne pas présumer que les règles actuelles détectent encore cette campagne de 2021.

Sources

- Features — Suricata
- Ubuntu Package Installation — Suricata
- Dépôt EveBox, version 0.28.0
- Fiche et corrigé Angry Poutine du dépôt SnailLabs-dev/Labs

- Capture `2021-09-10-traffic-analysis-exercise.pcap`, analysée avec Suricata 8.0.3